

中华人民共和国通信行业标准

YD/T [×××××]—[××××]
[代替 YD/T]

车联网安全态势感知平台技术要求

Technical requirements of security situational awareness platform for Internet of
vehicle

(报批稿)

[××××]-[××]-[××]发布

[××××]-[××]-[××]实施

中华人民共和国工业和信息化部 发布

目 次

前 言III

1 范围1

2 规范性引用文件1

3 术语和定义1

4 缩略语2

5 概述2

 5.1 平台体系2

 5.2 平台功能框架3

6 数据采集要求4

 6.1 数据来源4

 6.1.1 基础电信企业数据来源4

 6.1.2 车联网企业数据来源4

 6.2 数据采集5

 6.2.1 通用数据5

 6.2.2 基础电信企业侧网络安全数据5

 6.2.3 车联网企业侧网络安全数据6

7 数据预处理要求6

 7.1 数据分析6

 7.2 数据存储6

8 威胁风险分析要求7

 8.1 网络攻击分析7

 8.2 资产风险分析7

 8.3 异常行为分析7

9 监测管理协同要求8

 9.1 监测分析8

 9.2 监测告警8

 9.3 指令协同8

10 可视化展示要求8

11 安全要求9

 11.1 数据保密9

 11.2 身份鉴别9

 11.3 访问控制9

 11.4 安全审计10

前 言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由中国通信标准化协会提出并归口。

本文件起草单位：中国信息通信研究院、北京亚鸿世纪科技发展有限公司、郑州信大捷安信息技术股份有限公司、北京东方通网信科技有限公司、恒安嘉新(北京)科技股份公司、北京浩瀚深度信息技术股份有限公司、木卫四（北京）科技有限公司

本文件主要起草人：周成胜、赵爽、卜哲、于传若、王桂温、赵勋、庄建滨、刘双喜、曹光辉、卢泓宇、林飞、程红、麻心如、刘为华、崔婷婷、陈乔、孟娟、何文杰、庞绍敏、任翔。

车联网安全态势感知平台技术要求

1 范围

本文件规定了车联网安全态势感知平台技术要求，包括车联网安全态势感知平台数据采集、数据预处理、威胁风险分析、监测管理协同、可视化展示和安全等方面的要求。

本文件适用于车联网相关企业（包括基础电信企业、车联网企业）的车联网安全态势感知平台的设计、开发、测试验证等。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

GB/T 25069-2022 信息安全技术 术语

3 术语和定义

GB/T 25069界定的以及下列术语及定义适用于本文件。

3.1

车联网服务平台 IOV service platform

车联网的信息管理和服务平台，负责车辆及相关设备信息的汇聚、计算、监控和管理，提供主动安全、智能交通管控、远程诊断、电子呼叫中心、道路救援等应用服务。

3.2

车联网终端 vehicle terminal

智能网联汽车和安装在智能网联汽车上的设备，通过无线通信技术与互联网或其他车辆进行通信。

3.3

态势感知 situation awareness

在一定的时间和空间条件下，对环境因素的获取、理解以及对未来的发展趋势进行预测。

3.4

威胁告警 threat warning

基于威胁情报关联、流量特征分析和异常检测模型等方式，提取流量中的有效告警信息，用于记录已经发生的网络安全事件，及时发出告警。

3.5

通联记录 communication logs

车联网终端或车联网服务平台之间的通信活动记录，记录车联网终端和车联网服务平台相关的网络通信活动。

3.6

终端标识 vehicle identifier

识别车联网终端唯一性的标识。

注：车联网终端标识包括VIN码、IMEI、PEI等，是车联网终端的识别代码。

4 缩略语

下列缩略语适用于本文件。

APN	接入点名称	Access Point Name
APP	手机应用软件	Application
CAN	控制器局域网	Controller Area Network
FTP	文件传输协议	File Transfer Protocol
HTTPS	超文本传输安全协议	Hypertext Transfer Protocol Secure
IMEI	国际移动设备识别码	International Mobile Equipment Identity number
IOV	车联网	Internet of Vehicle
IP	网际互连协议	Internet Protocol
MQTT	消息队列遥测传输	Message Queuing Telemetry Transport
OBU	车载单元	On board Unit
OTA	空中下载技术	Over the Air Technology
PEI	永久设备标识符	Permanent Equipment Identifier
T-BOX	车联网通讯终端	Telematic BOX
TSP	汽车远程服务提供商	Telematics Service Provider
URL	统一资源定位器	Uniform Resource Locators
VIN	车辆识别号码	Vehicle Identification Number

5 概述

5.1 平台体系

车联网安全态势感知平台体系由两部分组成：一是监管平台，接收企业侧车联网安全态势感知平台的报送数据，并结合统计模型、关联算法、机器学习等技术手段对数据进行深入挖掘与分析，可向企业侧平台下发指令；二是企业侧平台，分为基础电信企业侧平台和车联网企业侧平台两部分。本标准主要对企业侧平台的技术要求进行定义。

基础电信企业侧主要对车联网终端、车联网服务平台的流量进行安全威胁分析，并将分析结果报送至监管平台；车联网企业侧主要收集车联网终端、车联网服务平台，以及车联网APP的监测结果，并对数据进行分析、加工后报送至监管平台。

车联网安全态势感知平台体系详见图1。

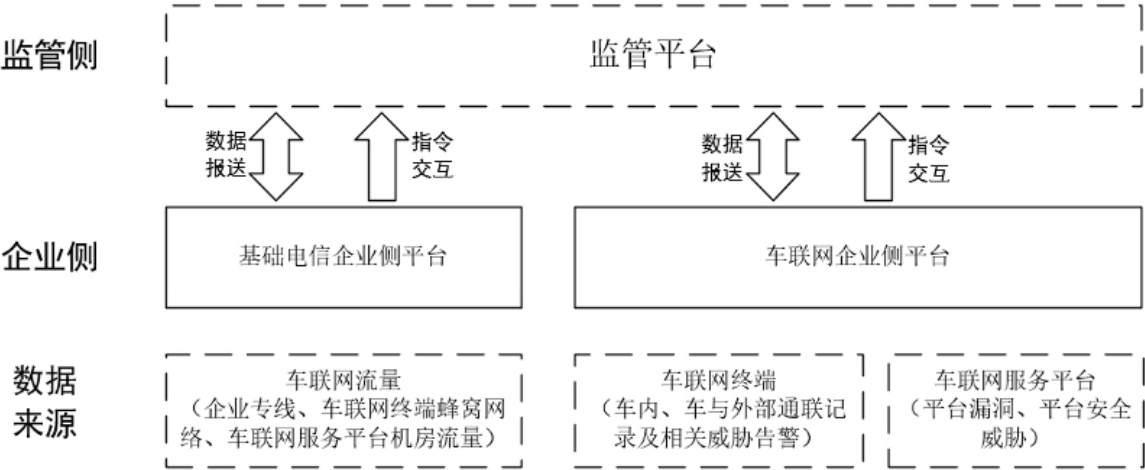


图1 平台体系

5.2 平台功能框架

企业侧平台通过提取车联网相关流量、威胁告警日志等数据，使用特征匹配、统计学和机器学习等方式，形成网络攻击检测、异常行为分析等模型，对车联网终端、车联网服务平台、车联网APP进行网络威胁风险分析，可实现针对车联网的安全监测、风险预警、态势感知、指令交互等功能。企业侧平台功能框架如图2所示。

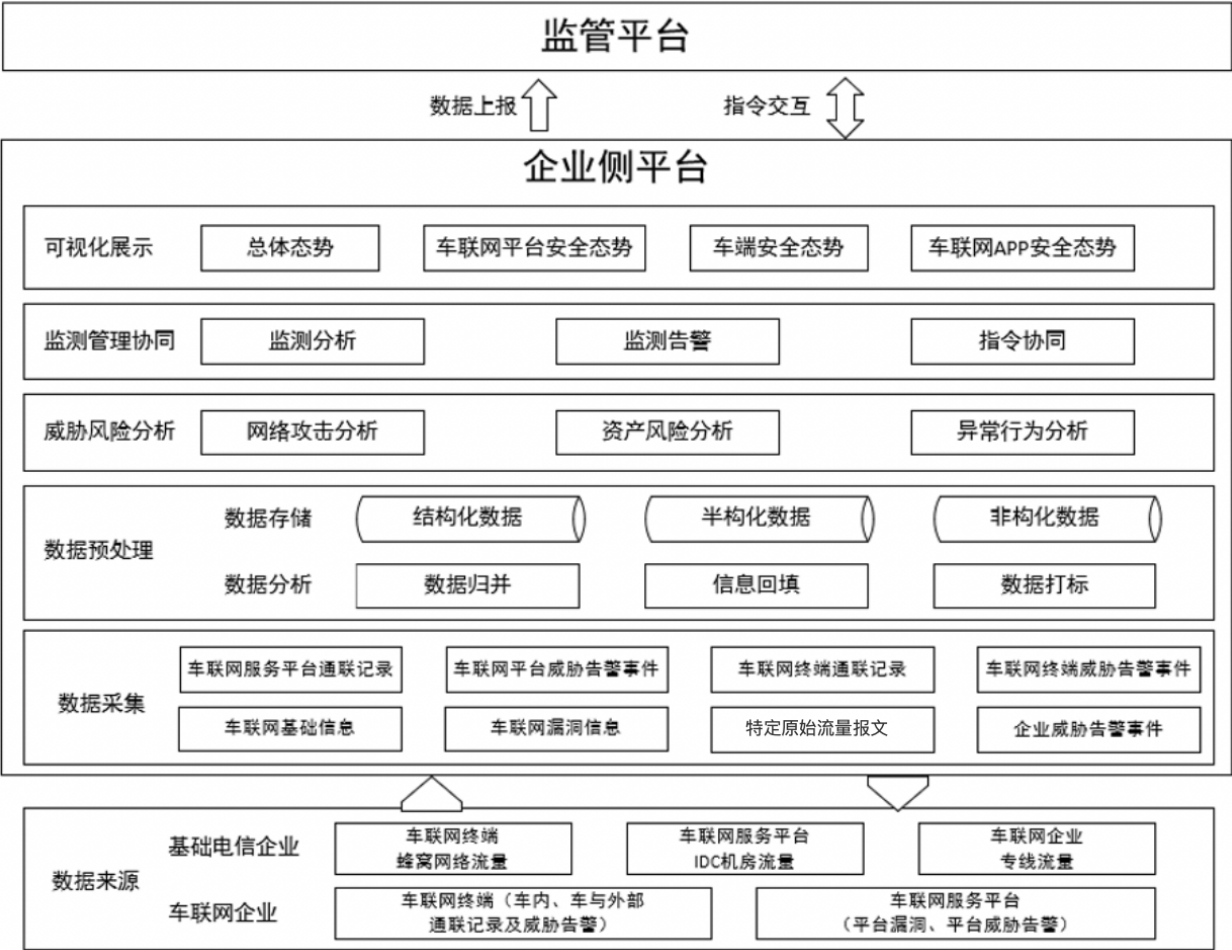


图2 平台功能框架

6 数据采集要求

6.1 数据来源

6.1.1 基础电信企业数据来源

基础电信企业数据来源要求如下：

- a) 应包括车联网终端与外部通信产生的流量，涉及各省移动互联网流量的通道汇聚点；
- b) 应支持采集 Gn、PI、S11、S1-U、N11、N3、N9 等接口的车联网流量；
- c) 采集范围应覆盖 2G、3G、4G、5G 及后续的移动通信网络制式流量；
- d) 应包括车联网服务平台流量。

6.1.2 车联网企业数据来源

车联网企业数据来源：

- a) 应包括车联网终端流量数据，涉及车内关键设备，以及车联网终端与外部交互的流量；
- b) 应包括自有车联网服务平台流量。

6.2 数据采集

6.2.1 通用数据

通用数据采集要求如下：

- a) 应支持采集以下车联网基础信息：
 - 1) 车联网终端信息：包括终端类型、终端品牌、终端唯一编号等信息；
 - 2) 服务平台信息：包括平台域名、接入 IP、URL 和服务类型等信息；
 - 3) 车联网 APN 信息：包括 APN 地址、APN 业务描述；
- b) 应支持数据导入，可导入的数据类型包括基础信息、威胁情报、漏洞信息等；
- c) 应至少支持两种数据传输方式，包括 Syslog、Web Service、FTP、SFTP 等方式。
- d) 宜支持报送流量中检测到的恶意样本，以及样本相关的基本信息数据；
- e) 宜留存符合监测规则的报文（PCAP 包形式）。

6.2.2 基础电信企业侧网络安全数据

基础电信企业安全数据采集要求如下：

- a) 应具备对基础电信企业采集位置的双向原始流量进行实时获取、协议解析、数据包重组和文件还原等操作的能力；
- b) 应具备基于 TCP/UDP 端口识别、报文负载特征识别、行为特征识别、关联分析检测等技术手段实现移动互联网通用网络协议的识别，可识别协议包括 GB/T 32960、JT/T 808、JT/T 809、HTTPS、HTTP、MQTT、COAP 等；
- c) 应具备识别各操作系统中 apk、xap、exe、sis、ipa 等格式的文件样本的能力，可识别出在车联网中传播的恶意的 APP，并具备对样本哈希值、下载地址、控制端等的识别能力；
- d) 应采集通联记录数据，包括车联网终端与车联网服务平台、车联网终端与第三方服务平台之间的通信记录，采集字段包括源 IP、源端口、目的 IP、目的端口、上行流量大小、上行流量包数、下行流量大小、下行流量包数、URL、终端标识（如 IMEI、PEI）等；
- e) 应采集车联网终端、车联网服务平台相关通信流量的威胁告警数据，包括恶意受控事件、恶意传播事件、网络安全攻击事件等，采集字段包括 IP、源端口、目的 IP、目的端口、上行流量大小、上行流量包数、下行流量大小、下行流量包数、URL、终端标识（如 IMEI、

PEI)、事件类型、危害等级、攻击阶段、攻击载荷等。

6.2.3 车联网企业侧网络安全数据

车联网企业网络安全数据采集要求如下：

- a) 应采集通联记录数据，包括车联网终端内部交互，以及车联网终端与车联网服务平台（含第三方服务平台）之间的通信记录，采集字段包括源 IP、源端口、目的 IP、目的端口、上行流量大小、上行流量包数、下行流量大小、下行流量包数、URL、终端标识（如 VIN）等；
- b) 应采集车联网终端的网络入侵监测防御系统或主机防护等系统的安全事件日志，采集字段包括事件类型、事件时间、事件描述、源 IP、源端口、目的 IP、目的端口、威胁等级、攻击载荷、CANID 等；
- c) 应支持采集车联网服务平台的网络入侵监测防御系统或主机防护等系统的安全事件日志，采集字段包括事件类型、事件时间、事件描述、源 IP、源端口、目的 IP、目的端口、威胁等级、攻击载荷等；
- d) 应支持采集企业使用的硬件、软件、信息系统和 APP 等相关漏洞信息，采集字段包括漏洞名称、编号、威胁等级、简介、受影响实体等。

7 数据预处理要求

7.1 数据分析

数据分析要求如下：

- a) 应支持针对数据中格式不一致、数据输入错误、数据不完整、存在无效数据等问题，进行清洗过滤；
- b) 应支持对不同类型的数据进行关联补齐，将存在关联性的数据经过关联补齐，能够形成完整数据，丰富数据本身，以便于后期的统计分析；
- c) 应支持将数据标签化，对原数据进行标记，其中车联网终端信息应包含终端类型、终端型号、品牌信息；车联网服务平台应包含平台名称、服务地址；
- d) 应支持 TB 级或以上数据计算。

7.2 数据存储

数据存储要求如下：

- a) 应支持存储结构化数据、半结构化和非结构化数据；

- b) 应支持存储包括业务数据（如日志数据、流量数据等）、管理数据（如告警策略、系统账号、系统日志、操作日志等）和知识数据（如车联网终端信息、位置信息、漏洞信息、规则等）；
- c) 数据存储时长要求：
 - 1) 威胁告警日志应至少存储180天，通联记录应至少存储30天；
 - 2) 恶意样本文件及样本相关基础信息数据（哈希值、样本类型等）应至少存储60天；
 - 3) 原始数据报文文件（原始流量PCAP包）及相关信息应至少存储7天；
 - 4) 平台维护管理产生的操作记录数据应至少存储180天；
- d) 应提供本地数据备份与恢复功能，进行定期备份，或提供多副本备份机制；备份数据应与原数据具有相同的访问控制权限和安全存储要求。

8 威胁风险分析要求

8.1 网络攻击分析

网络攻击分析要求如下：

- a) 应支持网络攻击分析，攻击类别包括漏洞利用攻击、拒绝服务攻击、Web应用攻击、暴力破解攻击等；
- b) 应支持攻击特点分析，包括攻击来源、攻击对象、攻击方式、攻击趋势等；
- c) 应具备标记各类安全事件的攻击阶段、威胁方向、危害等级等的的能力；
- d) 应具备对采集的各类威胁告警日志进行深度分析的能力，利用数据进行关联、碰撞等分析方法发现未知威胁类型；
- e) 应支持对网络攻击端进行分析，建立攻击方画像。

8.2 资产风险分析

资产风险分析要求如下：

- a) 应支持判断车联网终端的受控状态，评估终端风险等级；
- b) 应支持建立车联网终端的风险画像，包括品牌、型号、漏洞、相关事件信息、风险等级，以及终端受控状态；
- c) 应支持车联网服务平台的风险画像，包括平台名称、漏洞类型、漏洞等级、相关事件信息。

8.3 异常行为分析

异常行为分析要求如下：

- a) 应具备对车联网终端和车联网服务平台异常行为的监测能力，能够监测流量变化等异常情况；
- b) 应支持通过行为基线、关联分析等技术发现用户或实体的异常行为，如：异常访问、操作异常、数据异常等；

9 监测管理协同要求

9.1 监测分析

监测分析要求如下：

- a) 应支持按照终端标识、品牌、车型、攻击类型、时间等信息，对车联网终端风险进行查询和统计；
- b) 应支持按照平台名称、端口、服务等信息，对车联网服务平台风险进行查询和统计；
- c) 应支持按照攻击来源国家、攻击IP、攻击类型、时间、危害等级等信息进行威胁告警数据的查询和统计；

9.2 监测告警

监测告警要求如下：

- a) 应支持在安全事件或异常行为发生时，及时发送告警信息；
- b) 应支持进行监测范围和告警规则的自定义；
- c) 应支持对告警策略进行分级，对不同级别的安全事件分别进行告警；
- d) 监测告警方式应包含以下一种：平台、短信、电子邮件；
- e) 应具备告警规则库，并支持通过云端同步或人工导入的方式更新；

9.3 指令协同

指令协同要求如下：

- a) 应具备主动报送监测的基础信息、通联记录和威胁告警数据的能力；
- b) 应具备预警、查询、基础资源同步指令交互的能力。支持解析并执行指令内容，并向监管平台反馈指令执行结果数据；

10 可视化展示要求

可视化展示要求如下：

- a) 应支持车联网总体态势展示，包括活跃车联网终端分布、车联网终端被攻击排名、被攻击车联网终端类型排名等；
- b) 应支持车联网服务平台安全态势展示，包括车联网服务平台被攻击趋势分析、遭受攻击类型排名、平台漏洞类型分布等；
- c) 应支持车联网终端安全态势展示，包括遭受攻击类型分布、被攻击车联网终端排名、攻击来源国家排名等；
- d) 应支持车联网APP安全风险态势展示，包括恶意APP排名、APP漏洞类型分布等；
- e) 应支持两种以上视图展示以上维度，包括趋势图、柱状图、饼图等。

11 安全要求

11.1 数据保密

数据保密要求如下：

- a) 应具备密码算法和密钥管理等数据保密性保护能力，其算法强度应符合国家相关规定；
- b) 应采用加密、防泄露等技术手段来保障所采集的重要数据在采集、存储、传输、使用过程中的保密性；
- c) 应针对数据全生命周期采取有效技术保护措施，防范数据泄露、毁损、丢失、篡改、误用、滥用等风险；对于敏感数据的存储和传输，需要进行脱敏处理，严格保护用户隐私不被泄露。

11.2 身份鉴别

身份鉴别要求如下：

- a) 应对本平台登录的用户实施身份标识和鉴别，身份标识和用户初次登录使用口令具有唯一性，鉴别信息应具有复杂度要求并定期更换。
- b) 应设置系统管理员、账号管理员和审计管理员等角色。其中，系统管理员应具备系统配置、数据管理等权限。账号管理员应具备账号分配、访问控制等权限。审计管理员应具备安全审计等权限。

11.3 访问控制

访问控制要求如下：

- a) 支持访问控制功能，对登录的用户分配账户和权限。由账号管理员配置访问控制策略，访问

控制策略规定用户对平台的访问规则。

- b) 支持角色划分功能，授予不同账号为完成各自承担任务所需的最小权限，实现管理用户的权限分离，并在它们之间形成相互制约的关系。

11.4 安全审计

安全审计要求如下：

- a) 平台用户登录和注销日志；
- b) 平台安全策略变更的操作日志，平台用户角色的增加、删除和属性修改等操作；
- c) 审计记录应记录：发生的日期和时间、事件的类型、主体身份，以及事件成功或失败的状态。
- d) 应对所有审计行为留有记录并独立存储，严禁在任何情况下开放对审计结果的修改与删除权限。